

CISSP Printable Practice Exam 04 - Domain 4 - Communication and Network Security

Domain 4

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP1-060)

Scenario: A financial services firm uses an encrypted web application. Its current network sensor records source and destination IP addresses and TCP ports, but the incident response team must distinguish approved application transactions from malicious requests inside established sessions.

Which change would BEST provide the required visibility?

- A. Add a passive tap that records the same network-layer headers at higher speed
- B. Deploy application-aware inspection where authorized TLS traffic can be decrypted and examined
- C. Replace the access switches with devices that maintain larger MAC address tables
- D. Collect additional routing metrics from the edge routers

Question 2 (CISSP1-061)

Scenario: A manufacturer enables IPv6 on a dual-stack production network. Firewall rules and monitoring signatures have been carefully tuned for IPv4, but no equivalent review has been performed for IPv6.

What should the security architect do FIRST?

- A. Disable IPv4 so all traffic follows a single protocol stack
- B. Block all ICMPv6 messages at the perimeter
- C. Create equivalent IPv6 filtering and monitoring coverage and test both protocol paths
- D. Rely on network address translation to conceal all internal IPv6 addresses

Question 3 (CISSP1-062)

Scenario: A university must deliver the same live lecture stream to hundreds of authorized receivers across a managed campus network. The network team wants to minimize duplicate traffic across shared links without sending the stream to every host.

Which transport approach BEST meets the requirement?

- A. A separate unicast stream for every receiver
- B. A subnet-wide broadcast stream
- C. A multicast stream with controlled group membership
- D. An anycast address assigned to every receiver

Question 4 (CISSP1-063)

Scenario: A research organization permits outbound HTTPS through a stateful firewall. Analysts discover that unmanaged hosts can encapsulate an unauthorized protocol inside allowed TLS connections, preventing the firewall from classifying the inner traffic.

Which control would BEST address the risk while preserving approved web access?

- A. Allow outbound connections based only on destination port 443
- B. Increase the firewall session timeout for encrypted connections
- C. Apply authenticated application-aware egress controls at an authorized inspection point
- D. Replace all internal private addresses with publicly routable addresses

Question 5 (CISSP1-064)

Which TWO statements correctly describe network-layer visibility? Select 2 of the 5 options below.

- A. A Layer 2 switch normally forwards frames using MAC address information.
- B. A standard router selects paths primarily by inspecting HTTP request methods.
- C. A transport-layer control can use TCP or UDP port information when enforcing policy.
- D. An application proxy is limited to source and destination MAC addresses.
- E. An Ethernet broadcast is routed unchanged across every enterprise subnet by default.

Question 6 (CISSP1-065)

Scenario: A regional retailer is deploying an Internet-facing ordering server that must query an internal database. Administrators also need to manage the server from a protected workstation network.

Which architecture provides the BEST defense in depth?

- A. Place the web server and database on the user LAN and filter only Internet traffic
- B. Place the web server in a DMZ, allow only required database flows, and use a separate managed administration path
- C. Place the database in the DMZ and allow the web server unrestricted access to the internal network
- D. Place both servers directly on the Internet and rely on host authentication

Question 7 (CISSP1-066)

Scenario: A consulting firm is replacing a shared wireless passphrase because former contractors may retain it. The firm wants per-user or per-device revocation and strong resistance to credential-capture access points.

Which solution BEST satisfies these objectives?

- A. WPA3-Enterprise with certificate-based EAP authentication and validated server certificates
- B. WPA3-Personal using one complex passphrase rotated annually
- C. A hidden network name combined with MAC address filtering
- D. An open wireless network that requires users to accept a captive portal

Question 8 (CISSP1-067)

Scenario: A logistics company adopts software-defined networking. A centralized controller programs forwarding behavior across many data-plane devices, increasing the impact of controller compromise.

What is the MOST important security design consideration?

- A. Permit management access from every production subnet to simplify operations
- B. Protect controller access with strong authentication, restricted management paths, and resilient deployment
- C. Move all packet-forwarding decisions from switches to end-user devices
- D. Use a single shared administrator account to maintain policy consistency

Question 9 (CISSP1-068)

Scenario: A media company runs hundreds of rapidly changing cloud workloads on the same private address space. Traditional subnet boundaries do not adequately restrict east-west communication between application tiers.

Which approach BEST reduces lateral movement without depending solely on subnet placement?

- A. Assign policy to workload identities and permit only required service-to-service flows
- B. Increase the size of each subnet so workloads change addresses less often
- C. Route all internal traffic through a public content delivery network
- D. Allow unrestricted traffic between private addresses and inspect only north-south flows

Question 10 (CISSP1-069)

Scenario: An online publisher uses a content delivery network for a public site. The origin server should accept content requests only through the delivery service, and administrative access must remain separate from the public delivery path.

Which TWO controls BEST support the design? Select 2 of the 5 options below.

- A. Restrict origin ingress to authenticated or approved delivery-service paths.
- B. Expose the origin directly so clients can bypass a failed delivery node.
- C. Use a separate, strongly authenticated management path for the origin.
- D. Permit administrative access through the same anonymous public endpoint.
- E. Trust any request containing a client-supplied forwarding header.

Question 11 (CISSP1-070)

Scenario: A hospital wants to detect malicious traffic on a latency-sensitive clinical network. Blocking a legitimate session could disrupt care, and the organization has not yet tuned signatures against representative traffic.

What is the BEST initial deployment approach?

- A. Deploy the system inline in blocking mode with every signature enabled
- B. Begin with passive detection, tune and validate alerts, then evaluate selective prevention
- C. Disable network monitoring because availability has priority
- D. Route clinical traffic through an unauthenticated public proxy

Question 12 (CISSP1-071)

Scenario: A government agency must enforce destination categories, authenticate employees, scan permitted web downloads, and retain centralized records of outbound browser requests.

Which component BEST meets these requirements?

- A. A forward proxy with user authentication and content inspection
- B. A Layer 2 repeater on each office floor
- C. A load balancer in front of the agency's public website
- D. A passive fiber coupler with no policy engine

Question 13 (CISSP1-072)

Scenario: At a branch office, unused wall jacks remain connected. The security team also observes attempts to impersonate authorized device addresses and introduce unauthorized switching behavior.

Which action would MOST directly reduce these access-layer risks?

- A. Disable unused ports and enforce authenticated network admission with appropriate switch protections
- B. Increase the dynamic routing protocol's convergence timer
- C. Publish the switch management interface through the guest wireless network
- D. Move the branch's public web server into the employee VLAN

Question 14 (CISSP1-073)

Scenario: A software company uses load balancers to distribute customer requests across application servers. Security review finds that health checks use a privileged application account and the management interface is reachable from the public listener network.

Which remediation is BEST?

- A. Use least-privileged health checks and isolate management on a restricted administrative network
- B. Disable health checks and send traffic to every server regardless of status
- C. Grant the health-check account database administrator privileges
- D. Expose each application server directly to eliminate the load balancer

Question 15 (CISSP1-074)

Scenario: A professional services firm permits employee laptops on its wired network. It must verify device identity and security posture before granting access, while giving noncompliant devices a limited path to approved remediation services.

Which TWO capabilities BEST meet the requirement? Select 2 of the 5 options below.

- A. Authenticated network admission tied to device or user identity
- B. Unrestricted production access based only on possession of an Ethernet cable
- C. Dynamic placement of failed devices into a restricted remediation segment
- D. Permanent administrator privileges for every admitted endpoint
- E. Disabling endpoint posture assessment to reduce connection time

Question 16 (CISSP1-075)

Scenario: A construction company needs persistent encrypted connectivity between two offices across an untrusted network. Internal hosts should not require individual tunnel configuration, and the original internal packets should be carried between security gateways.

Which solution BEST satisfies the requirements?

- A. IPsec tunnel mode between the two gateways
- B. IPsec transport mode configured only between two individual workstations
- C. An unencrypted application proxy at one office
- D. A broadcast relay across the untrusted network

Question 17 (CISSP1-076)

Scenario: A legal services organization is deploying Internet-connected voice communications. It must protect call setup and media confidentiality, limit unauthorized sessions, and preserve acceptable call quality.

Which design is MOST appropriate?

- A. Protect signaling and media with appropriate secure protocols, enforce sessions at a voice-aware boundary control, and apply quality-of-service policy
- B. Encrypt signaling only because media streams contain no sensitive information
- C. Place all voice endpoints directly on the Internet to avoid boundary latency
- D. Use the data network without segmentation, session controls, or traffic prioritization

Question 18 (CISSP1-077)

Scenario: A utility must allow a maintenance vendor to administer one internal appliance during approved service windows. The utility requires individual accountability, minimal

network exposure, and rapid revocation when the engagement ends.

Which approach BEST meets these requirements?

- A. Provide a shared VPN account with access to the full operations network
- B. Use individually authenticated access through a monitored gateway, restricted to the target and approved times
- C. Publish the appliance's management interface directly to the Internet
- D. Allow the vendor to reuse an employee's permanent remote-access credentials

Question 19 (CISSP1-078)

Scenario: An engineering firm will discuss confidential designs in video conferences with invited external partners. Previous public meeting links were forwarded to unintended participants, and recordings were retained without clear ownership.

What should the security manager recommend FIRST?

- A. Use authenticated invitations, controlled admission, restricted sharing, and an approved recording-retention policy
- B. Post one reusable meeting link publicly so partners can join easily
- C. Rely on participants to identify unexpected attendees after the meeting
- D. Permit unrestricted local recordings because storage is outside the network path

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP1-060) - Correct: B

Application-aware inspection at an authorized decryption point can evaluate requests within TLS sessions. A faster tap still sees only encrypted payloads and headers, while MAC tables and routing metrics provide link- or network-layer information rather than application transaction content.

Question 2 (CISSP1-061) - Correct: C

A dual-stack environment creates two usable network paths, so security policy, filtering, and monitoring must cover and test both. Disabling IPv4 may disrupt services, blocking all ICMPv6 interferes with essential IPv6 functions, and address translation is neither a substitute for controls nor generally required for IPv6.

Question 3 (CISSP1-062) - Correct: C

Multicast efficiently distributes one stream to subscribed group members and avoids a separate copy for every receiver. Unicast duplicates traffic, broadcast reaches hosts that did not request the content, and anycast routes a client toward one of several service instances rather than distributing one stream to many receivers.

Question 4 (CISSP1-063) - Correct: C

Authenticated, application-aware egress inspection can distinguish approved web use from an unauthorized protocol hidden within TLS. Port-only rules cannot identify the inner protocol, longer timeouts do not improve classification, and public addressing does not solve encapsulation or inspection limitations.

Question 5 (CISSP1-064) - Correct: A, C

Layer 2 switches use MAC information, and transport-aware controls can evaluate TCP or UDP ports. Routers primarily make forwarding decisions from network-layer addressing, application proxies can inspect higher-layer content, and routers normally bound Ethernet broadcast domains rather than forwarding broadcasts everywhere.

Question 6 (CISSP1-065) - Correct: B

A DMZ limits exposure of the public server, narrowly scoped database rules reduce lateral movement, and a separate managed path protects administration. The other designs collapse trust boundaries, expose sensitive systems, or rely too heavily on host controls alone.

Question 7 (CISSP1-066) - Correct: A

WPA3-Enterprise with certificate-based EAP supports individual credentials, targeted revocation, and mutual authentication when clients validate the authentication server. A shared passphrase lacks granular revocation, while hidden names, MAC filtering, and captive portals do not provide equivalent authentication assurance.

Question 8 (CISSP1-067) - Correct: B

The controller is a high-impact control-plane component, so tightly restricted access, strong authentication, and resilience are essential. Broad management reachability and shared accounts increase compromise risk, while shifting forwarding decisions to endpoints defeats the intended architecture.

Question 9 (CISSP1-068) - Correct: A

Identity-based micro-segmentation follows dynamic workloads and limits communication to explicitly required flows. Larger subnets and unrestricted private traffic expand lateral movement opportunities, while a content delivery network is intended primarily for content

distribution and does not replace internal workload controls.

Question 10 (CISSP1-069) - Correct: A, C

Restricting origin ingress prevents direct bypass of the delivery layer, while a separate authenticated management path isolates privileged access. Direct exposure weakens origin protection, anonymous administration collapses trust boundaries, and client-supplied headers are not reliable proof of an approved path.

Question 11 (CISSP1-070) - Correct: B

Passive detection allows the hospital to establish accuracy and tune signatures without initially risking interruption of clinical traffic. Immediate broad blocking creates unacceptable false-positive risk, disabling monitoring sacrifices visibility, and a public proxy neither addresses the requirement nor protects the traffic.

Question 12 (CISSP1-071) - Correct: A

A forward proxy can mediate employee web requests, associate them with identities, enforce category policy, scan content, and centralize logs. Repeaters and passive media components do not enforce application policy, while an inbound load balancer serves a different traffic direction and purpose.

Question 13 (CISSP1-072) - Correct: A

Disabling unused ports removes easy physical entry points, while authenticated admission and switch safeguards address impersonation and unauthorized access-layer behavior. Routing timers do not secure wall jacks, and exposing management or moving a public server into the employee segment increases risk.

Question 14 (CISSP1-073) - Correct: A

Least-privileged health checks limit credential impact, and an isolated management plane reduces exposure of administrative functions. Disabling checks harms availability, additional privilege worsens compromise impact, and direct server exposure removes useful protection without correcting the underlying design.

Question 15 (CISSP1-074) - Correct: A, C

Authenticated admission establishes identity, and dynamic restricted placement lets noncompliant devices reach only remediation resources. Cable possession is not sufficient assurance, administrator privileges are unrelated and dangerous, and disabling posture checks defeats a stated requirement.

Question 16 (CISSP1-075) - Correct: A

IPsec tunnel mode between gateways encapsulates and protects the original packets for site-to-site connectivity without configuring every internal host. Host-only transport mode does not meet the network-wide requirement, and neither an unencrypted proxy nor a broadcast relay provides the required protected channel.

Question 17 (CISSP1-076) - Correct: A

Voice security requires protection of both signaling and media, controlled traversal of trust boundaries, and availability measures appropriate to real-time traffic. Signaling-only protection leaves conversations exposed, while direct exposure and an unsegmented, uncontrolled design increase attack and quality risks.

Question 18 (CISSP1-077) - Correct: B

An individually authenticated, monitored gateway with target and time restrictions provides accountability, least privilege, and straightforward revocation. Shared or borrowed

credentials defeat attribution, broad VPN access exceeds need, and direct Internet exposure unnecessarily increases attack surface.

Question 19 (CISSP1-078) - Correct: A

Authenticated invitations, admission controls, sharing restrictions, and governed recording retention address unauthorized attendance, content exposure, and information lifecycle risk together. Public reusable links, after-the-fact identification, and unrestricted recording do not provide preventive or accountable protection.